

Home Lab 3 — SOC Investigation

Security Operations & Incident Response | rigatechgirl.lv | 24 April 2026

Incident: INC-2026-0424-001 | Severity: HIGH (P1)

Attack Overview

Vector	What Happened	Outcome	User
OAuth Phishing (AiTM)	Phishing email → fake SharePoint login → credential + MFA token captured → OAuth consent granted → Graph API access → payroll data exfiltrated → BEC email sent to Finance	COMPROMISED	Nigar
Macro Document	Same phishing site served payment_list.docm → macro triggered PowerShell → EDR blocked and quarantined	BLOCKED	Emil

Timeline

Time	Event	Type
09:02	Phishing email delivered to 6 users from sharepoint-support.lv (SPF pass, DKIM fail, URL unknown)	Phishing
09:11	Nigar visits phishing URL — credentials and MFA token captured via AiTM proxy	Credential capture
09:13–14	Emil visits URL, opens payment_list.docm — macro attempts PowerShell — EDR blocks and quarantines	Blocked
09:15	Anna's link click blocked — URL now classified as phishing	Blocked
09:16	Nigar logs in legitimately from Riga, Latvia (MFA satisfied)	Normal login
09:22	Attacker logs in from Amsterdam via commercial hosting IP — impossible travel (6 min after Riga)	Takeover
09:23	OAuth consent granted for 'SharePoint Document Viewer' (Mail.Read, offline_access) — persistent token created	Persistence
09:26	Inbox rule 'Archive notifications' created — hides emails with keywords: invoice, payment, bank, transfer	Hiding
09:29–36	148 emails and 12 attachments read via Graph API — search terms: invoice, payment, bank, salary, contract	Exfiltration
09:37	Payroll_export_Q1.xlsx accessed — names, PIDs, salaries, bank accounts of all employees	Exfiltration
09:40	BEC email sent from Nigar's account to Finance — 'Updated bank details for April payments' — Finance did not action it	BEC attempt
10:05	SOC receives 5 correlated alerts — ticket opened	Detection

Customer Questions & Answers

Q1: What is the most likely attack path?

Answer:

- Phishing email with lookalike SharePoint domain sent to 6 users at 09:02
- Nigar clicked the link — AiTM proxy captured her credentials and MFA token in real time
- Attacker logged in from Amsterdam using the captured session token, bypassing MFA
- Rogue OAuth app consent granted — persistent Mail.Read + offline_access token created
- Graph API used to read 148 emails, 12 attachments, and payroll file (Payroll_export_Q1.xlsx)
- Inbox rule created to hide Finance replies — then BEC email sent at 09:40
- Parallel: same phishing site served Emil a macro document — EDR blocked PowerShell execution

Q2: Which alerts belong to the same incident?

Answer:

Alerts 1, 2, 3, and 5 are all part of the same Nigar account compromise:

Alert	Description	Role in Incident
A1	Suspicious login — unusual location	Attacker's Amsterdam session using captured AiTM token
A2	New mailbox rule on finance account	Hides Finance replies — part of BEC setup
A3	Bulk email access via Graph API	Data exfiltration — 148 emails, payroll file
A5	Internal email with updated bank details	The BEC attempt — sent from Nigar's compromised mailbox

Q3: Which alert may be a separate but related attempted compromise?

Answer:

Alert 4 (EDR blocked PowerShell on Emil's laptop) is separate but related. Same phishing campaign, different attack vector — macro document instead of AiTM credential harvest. No cloud compromise occurred. Emil's credential submission to the phishing page remains unconfirmed.

Q4: Is this a confirmed incident? Why?

Answer:

Yes — confirmed incident. Key reasons:

- Impossible travel: Riga login at 09:16, Amsterdam login at 09:22 — 6 minutes apart, 1,700 km distance
- Attacker actions fully logged in M365 Audit: OAuth consent, Graph searches, file access, inbox rule, BEC email
- Nigar confirms she did not travel, did not send the bank-details email, and did not create any inbox rule
- Finance independently confirms the suspicious email arrived from Nigar's account

Q5: What is the likely severity?

Answer:

HIGH — Priority 1 (P1)

- Full cloud account takeover with confirmed data exfiltration
- Payroll data accessed: names, PIDs, salaries, and bank accounts for all employees — GDPR notifiable
- Live BEC fraud attempt against Finance (narrowly avoided — Finance did not action it)
- OAuth persistence token still active until explicitly revoked

Q6: What evidence is strong?

Answer:

- Entra ID sign-in logs — impossible travel pattern is hard technical proof
- M365 Audit Logs — complete record of OAuth consent, Graph activity, inbox rule, BEC email with exact timestamps
- EDR logs — precise execution chain: Word → PowerShell blocked → quarantined
- Web proxy logs — confirms which users clicked the link and when
- Nigar's statement — fully consistent with technical evidence
- Finance statement — independently corroborates the BEC email and suspicious behaviour

Q7: What evidence is weak or needs confirmation?

Answer:

- Emil's credential status — proxy confirms he visited the URL but no log confirms if he entered credentials
- Finance, HR, office.admin click status — no proxy entries; unclear if they didn't click or aren't covered by proxy
- DKIM failure — suspicious but not conclusive on its own; lookalike domain is a stronger indicator
- Contents of new_bank_details.docx — Finance did not open it; fraudulent account details unknown until sandbox analysis

Q8: What should be contained immediately?

Answer:

1. Revoke all active Entra ID sessions for nigar.aliyeva@rigatechgirl.lv
2. Reset Nigar's Microsoft 365 password
3. Revoke all OAuth tokens and app consents — especially 'SharePoint Document Viewer'
4. Delete inbox rule 'Archive notifications' from Nigar's mailbox
5. Temporarily disable Nigar's account
6. Block domains sharepoint-support.lv and sharepoint-documents-login.lv at email gateway and DNS
7. Confirm Emil-Laptop quarantine; check Emil's Entra ID for unauthorised logins or OAuth consents
8. Instruct Finance to freeze pending bank detail changes and not open new_bank_details.docx
9. Force MFA re-registration for all 6 phishing email recipients
10. Preserve all logs — Entra ID, M365 Audit, EDR, Web Proxy — for forensic retention

Q9: What should be investigated next?

Answer:

- Confirm Emil's credential exposure — check Entra ID sign-ins and OAuth consents on his account
- Verify Finance, HR, office.admin click status — check proxy coverage gaps and sign-in anomalies
- Sandbox analysis of new_bank_details.docx and payment_list.docm
- Pull rogue OAuth app registration from Entra ID Admin Centre — client ID, redirect URIs
- Check Exchange Online for any external auto-forward rules
- Threat intel on phishing domains — WHOIS, hosting, known campaign links
- GDPR breach notification assessment with DPO — 72-hour window applies

Q10: Write a SOC/IR Ticket.**Answer:**

Field	Detail
IDENTIFICATION	
Ticket ID	INC-2026-0424-001
Date / Time	24 April 2026, 10:05
Customer	rigatechgirl.lv
Reported By	SOC — automated alert correlation, assigned by Mike
Escalation	IR Lead, CISO, DPO
CLASSIFICATION	
Type	AiTM Phishing / Account Takeover / BEC / Data Exfiltration
Classification	CONFIRMED INCIDENT
Severity	HIGH — P1
Status	OPEN — Containment in Progress
SCOPE	
Primary Compromised	nigar.aliyeva@rigatechgirl.lv
Secondary Affected	emil.ozols@rigatechgirl.lv — EDR block; credential status unconfirmed
Other Targeted	finance@, hr@, office.admin@rigatechgirl.lv — click status unconfirmed
Systems Affected	M365 (Exchange Online, OneDrive, Graph API, Entra ID), Emil-Laptop
Data Exfiltrated	Payroll_export_Q1.xlsx (names, PIDs, salaries, bank accounts) + 148 emails + 12 attachments
ATTACK & OUTCOME	
Attack Chain	Phishing → AiTM MFA bypass → OAuth consent → Graph API exfiltration → BEC email
Persistence	OAuth token (offline_access) + inbox rule 'Archive notifications'
BEC Outcome	Finance did not open attachment. No payments changed. No financial loss.
ACTIONS	
Immediate	Revoke sessions + OAuth; reset password; delete inbox rule; disable account; block domains; MFA re-registration

Investigate	Emil credential status; 3 remaining recipients; sandbox both files; GDPR assessment
Regulatory	GDPR notification likely required — consult DPO. 72-hour window applies.
Next Review	4 hours — confirm containment complete